12-MINUTE READ · 15-POINT CHECKLIST

Law 25 for *your next app.*

A plain-language privacy checklist for Québec businesses that collect personal information through a website, form, portal or app.



- [x] Privacy officer named
- [x] Only the data you need
- [x] Consent, per purpose
- [x] Tracking off by default
- [x] Incident register

WHY THIS MATTERS NOW

If your app collects a name, *Law 25 applies to you.*

Québec's Law 25 modernised the province's private-sector privacy law. It applies to every business in Québec that collects personal information, whatever its size: a contact form, a booking page, a client portal or a mailing list is enough.

It came in three waves

Sept 22, 2022	A person in charge of privacy; reporting and logging confidentiality incidents.
Sept 22, 2023	Most of the rest: policies, privacy impact assessments, consent, transparency, privacy by default, automated decisions, tracking technologies.
Sept 22, 2024	Data portability: people can ask for their data in a structured, commonly used format.

$25M or 4%

Maximum penal fine, or 4% of worldwide turnover if higher. Administrative penalties reach $10M or 2%.

LAW 25 / CAI ENFORCEMENT [1]

C$6.98M

Average cost of a data breach in Canada in 2025, up 10.4% in a year.

IBM COST OF A DATA BREACH 2025 [2]

The maximum fines make headlines, but for a small business the real costs are usually quieter: a complaint to the Commission d'accès à l'information (CAI), a lost contract because a client's procurement team asked privacy questions you couldn't answer, or customers who quietly stop trusting you.

The good news

Most of Law 25 is cheapest to do **while an app is being built**. Adding consent records, a data export or a delete process at design time costs a fraction of retrofitting them later. That's what this checklist is for.

This guide is general information to help you ask the right questions. It is not legal advice. Check your situation with a lawyer and the CAI's guidance (cai.gouv.qc.ca). Section numbers refer to Québec's Act respecting the protection of personal information in the private sector (CQLR c. P-39.1).

THE CHECKLIST · PART 1 OF 2

Before your app *goes live.*

01 **Someone is in charge of privacy.** By default it's the person with the highest authority in the company (the CEO or owner), who can delegate the role in writing. Their title and contact details must be published on your website. (s. 3.1)

02 **You did a privacy impact assessment (PIA).** Required for any project to acquire, develop or overhaul an information system or online service that handles personal information. It should be proportionate: for a small app, a few honest pages can be enough. The project must also allow data to be exported in a structured format. (s. 3.3)

03 **You collect only what you need,** and you decided why before collecting it. Every field on every form should have a reason. Do you need a date of birth, or just "over 18: yes"? (s. 4, 5)

04 **People are told, at collection, why and how** their information will be used, who will see it, that it may be stored outside Québec, and how to access, correct or withdraw consent. (s. 8)

05 **Consent is clear and separate for each purpose.** In plain language, not buried in the terms. Sensitive information (health, finances, biometrics and the like) needs express consent. Under 14? A parent or guardian consents. (s. 12, 14)

06 **Privacy is the default.** An online product or service offered to the public has its privacy settings at the most protective level without the user changing anything. Tracking features that identify, locate or profile people are off until the person turns them on. (s. 8.1, 9.1)

07 **A privacy policy is published** in clear, simple terms, wherever you collect information through technology, plus information about your internal governance policies. (s. 3.2, 8.2)

08 **Transfers outside Québec are assessed.** If your hosting, email or AI provider is elsewhere (including another province, according to many practitioners), assess the protection the data will get and sign a written agreement first. (s. 17)

Before launch, *and every day after.*

09 **Security fits the sensitivity.** Encrypted connections, staff see only what their job needs, strong sign-in (with a second step for admins), backups you've actually tested, and logs of who accessed what. (s. 10)

10 **You know when data will be deleted.** When the purpose is achieved, information is destroyed or properly anonymised. Write a retention period for each kind of data, and make the app enforce it. (s. 23)

11 **Automated decisions are disclosed.** If a decision about someone is made *only* by automated processing (an AI score, an automatic refusal), you tell them, and on request explain the main factors and offer a review by a person. (s. 12.1)

12 **Incidents are logged and, when serious, reported.** Keep a register of every confidentiality incident, even minor ones. If there's a risk of serious injury, notify the CAI and the people affected promptly. (s. 3.5 to 3.8)

13 **Requests are answered within 30 days.** People can ask to see, correct or (in some cases) delete their information, or to stop its dissemination. Have a simple process and a template reply. (s. 27, 28, 28.1, 32)

14 **Data portability works.** Since September 2024, people can ask for the computerised information they gave you in a structured, commonly used technological format, for themselves or another organisation. (s. 27)

15 **Your vendors are under contract.** Anyone who handles personal information for you (hosting, email, payroll, developers) is bound by a written agreement on confidentiality and use. (s. 18.3)

A score for yourself

Count the items you could prove today, with a document or a screen you could show. 12 to 15: you're in good shape. 7 to 11: pick the two riskiest gaps and close them this quarter. Under 7: start with items 1, 3 and 12, which cost almost nothing.

COPY AND PASTE

Privacy requirements *for your developer.*

Add this block to your app brief (see guide 02). Any competent team can price it, and it turns legal duties into things that can be tested.

PRIVACY AND DATA PROTECTION REQUIREMENTS

- [ ] **Consent records:** store who consented, to which purpose, the exact wording or version shown, when, and how. Consent boxes are unticked by default, one per purpose.
- [ ] **Notice at collection:** every form shows a short notice (purpose, who sees it, link to the privacy policy and to the privacy officer's contact).
- [ ] **Roles and least privilege:** staff roles see only the fields their job needs; permissions are enforced on the server.
- [ ] **Strong sign-in:** multi-factor authentication for all staff and admin accounts.
- [ ] **Audit log:** record views and changes of sensitive records and all admin actions (who, what, when).
- [ ] **Encryption:** HTTPS everywhere; data and backups encrypted at rest; restore tested before launch.
- [ ] **Retention:** a configurable retention period per data type, with automatic deletion or anonymisation.
- [ ] **Export:** staff can export one person's data in a structured format (CSV or JSON) within minutes.
- [ ] **Deletion:** a documented way to delete a person's data, including from backups on rotation.
- [ ] **Tracking off by default:** no analytics, pixels or third-party scripts that identify, locate or profile visitors until they opt in. The cookie choice actually blocks scripts.
- [ ] **Hosting:** name the hosting region and every service that receives personal data (sub-processors). Prefer Canadian hosting where possible.
- [ ] **Automated decisions:** any fully automated decision about a person is flagged, explained in plain words, and can be reviewed by staff.
- [ ] **Language:** privacy notices and consent text available in French for Québec users.

Acceptance test idea: ask a colleague to sign up, request their data, and delete their account. Time each step. Each should take minutes, not days.

WORKSHEET · DATA MAP

Every field, *one honest line.*

List every piece of personal information your app (or form) collects. If you can't fill in the "why" column, you probably shouldn't collect it. This table is also the backbone of your privacy impact assessment.

FIELD	WHY WE NEED IT	REQUIRED?	WHO CAN SEE IT	STORED WHERE	KEPT FOR	SENSITIVE?
Phone number	Call about delivery issues	Optional	Office, driver on the day	App DB, Canada	12 months after last order	No

Don't forget the hidden fields: IP addresses in logs, uploaded photos and files, free-text notes your staff write about customers, and data inside email notifications.

And the hidden places: spreadsheets exported "just once", shared drives, staff phones, the developer's test copy (which should use fake data).

BONUS · EMAIL LISTS

Collecting emails? *CASL comes too.*

Law 25 governs how you handle personal information. Canada's Anti-Spam Legislation (CASL) governs the commercial emails and texts you send. If your app or website has a newsletter sign-up, a free download or a "keep me posted" box, both apply.

Getting consent the right way

- ✓ **An unticked box** the person ticks themselves. Pre-ticked boxes and "by continuing you agree" don't count as express consent.
- ✓ **Say why:** "Send me the guide and occasional tips by email."
- ✓ **Say who:** your business name and contact details (mailing address, plus phone, email or website).
- ✓ **Say they can withdraw** consent at any time.
- ✓ **Keep proof:** when, where, and the exact wording. The burden of proof is on the sender.

Every message you send

- ✓ **Identifies you** clearly, with contact information.
- ✓ **Has a working unsubscribe** that's easy and free, and is honoured within 10 business days.
- ✓ **Implied consent expires:** an existing business relationship from a purchase lasts two years; an enquiry, six months. Ask for express consent before it runs out.
- ✓ **Express consent doesn't expire** until the person unsubscribes.

Why it's worth getting right

CASL penalties can reach **$1 million per violation for individuals and $10 million for businesses**. Enforcement mostly targets serious cases, but a clean consent record also makes your emails more welcome, and your list far more valuable. [3]

The simplest compliant pattern for a free guide

Email field → one **unticked** box: "Yes, also send me occasional tips from [Company]. I can unsubscribe at any time." → send the guide whether or not they tick it → add them to your newsletter only if they did, and store the record.

THIS MONTH

Five moves *for the next 30 days.*

- [ ] **Name your privacy officer** and put their title and a contact address on your website.
- [ ] **Do the data map** for your busiest form or app. Delete one field you don't need.
- [ ] **Start an incident register**: a simple table with date, what happened, who was affected, what you did.
- [ ] **List your vendors** that touch personal data, and where they store it.
- [ ] **Paste the developer requirements** into the brief for your next project, or ask your current developer which ones you already meet.

Privacy by design is part of how we build

Every Addanapp project is built with Law 25 and PIPEDA in mind, with Canadian hosting on request. If you'd like the requirements on page 5 priced for your app, send us a brief.

SOURCES

1. Act respecting the protection of personal information in the private sector, CQLR c. P-39.1, as amended by the Act to modernize legislative provisions as regards the protection of personal information (S.Q. 2021, c. 25, "Law 25"): penalties under ss. 90.12 and 91. Summaries by Osler, Gowling WLG and McCarthy Tétrault. Commission d'accès à l'information du Québec guidance, cai.gouv.qc.ca.
2. IBM, "Cost of a Data Breach Report 2025" (Canadian results reported 30 July 2025): average C$6.98 million; global average US$4.44 million.
3. Canada's Anti-Spam Legislation (S.C. 2010, c. 23) and CRTC guidance; Innovation, Science and Economic Development Canada, fightspam.gc.ca.

Addanapp

FROM THE TEAM AT ADDANAPP.COM

Know what you need? *We'll tell you what it costs.*

Addanapp is a Montréal software studio. We build business apps, portals, back-offices and integrations at AI speed, and a senior engineer signs off every change before it reaches you.

A fixed price first
Every request is quoted before work starts. Nothing starts until you approve.

No acceptance, no invoice
You test it on a staging version. If it doesn't meet the criteria, we fix it at no extra cost.

Human-validated
AI drafts, engineers decide. Line-by-line review, tests and security checks on every change.

You own everything
Code, data and accounts are yours from day one. Built with Law 25 and PIPEDA in mind.

Send a short brief (the template in guide 02 is perfect) and an engineer, not a salesperson, will reply with questions or a fixed quote.

addanapp.com →

THE FREE GUIDE SERIES

01 Your Spreadsheet Is Already an App
02 The One-Page App Brief
03 AI-Built, Human-Signed
04 Build, Buy or Bolt On
05 **Law 25 for Your Next App**

© 2026 Addanapp. Edition 1 · November 2026. You're welcome to share this PDF unchanged. General information only, not legal, tax or financial advice: check the specifics of your situation with a qualified professional. Figures cited were accurate to their sources at the time of writing; see the Sources section. Company names in examples are fictional unless a source is cited.